

1. Поняття залишкового ризику. Механізми обробки залишкового ризику (10 балів)

Залишковий ризик — це ризик, який залишається після впровадження всіх можливих та доцільних заходів безпеки. Жодна система не може бути повністю захищеною, тому завжди є певна ймовірність, що загроза реалізується, навіть після застосування заходів захисту.

Формально:

Залишковий ризик = Початковий ризик – Ризик, зменшений заходами безпеки

Приклад:

Сервер має загрозу атаки через відкритий порт. Після впровадження міжмережевого екрану (файрвола) та оновлень ПЗ ризик зменшується, але повністю не зникає (можливі нульові дні, помилки конфігурації тощо) — це і є залишковий ризик.

Механізми обробки залишкового ризику:

1. **Прийняття ризику (Risk Acceptance):**

Організація погоджується на наявність залишкового ризику, визнаючи, що витрати на подальше зниження ризику перевищують вигоди.

2. **Передача ризику (Risk Transfer):**

Перенесення відповідальності за ризик на іншу сторону. Наприклад:

- о страхування кіберризиків,
- о передача частини функцій на аутсорс (наприклад, до хмарного провайдера з високим рівнем безпеки).

3. **Уникнення ризику (Risk Avoidance):**

Повна відмова від дій, пов'язаних із ризиком (наприклад, не використовувати вразливу технологію або сервіс).

4. **Зменшення впливу (Risk Mitigation):**

Додаткові заходи для зменшення **наслідків** реалізації загроз:

- о резервне копіювання,
- о план реагування на інциденти,
- о розподілення ресурсів, щоб уникнути одного пункту відмови.

2. Що являє собою ризик з точки зору інформаційної безпеки (5 балів)

Ризик в інформаційній безпеці — це ймовірність того, що загроза реалізується через вразливість системи та спричинить шкоду інформаційним активам (конфіденційності, цілісності або доступності інформації).

Складові ризику:

- **Актив (ресурс):** наприклад, база даних, сервер, документи.
- **Загроза:** потенційна подія, яка може завдати шкоди (наприклад, хакерська атака, витік даних).

- **Вразливість:** слабе місце, яке може бути використане для реалізації загрози.
- **Імовірність:** наскільки часто або ймовірно відбудеться інцидент.
- **Наслідки (вплив):** фінансові втрати, пошкодження репутації, юридичні наслідки.

Формула (спрощено):

Ризик = Імовірність × Наслідки

1. Поясніть етап оброблення ризику з точки зору ДСТУ ІЕС/ISO 31010:2013 (10 балів)

Оброблення ризику (Risk Treatment) — це один із ключових етапів процесу управління ризиками, описаний у стандарті ДСТУ ІЕС/ISO 31010:2013. Він передбачає **вибір і впровадження заходів**, спрямованих на **зменшення, утримання, усунення або передачу ризиків** до прийнятного рівня.

Основні дії в межах етапу оброблення ризику:

1. Оцінка варіантів обробки ризику:

Розгляд доступних стратегій для кожного визначеного ризику (наприклад, уникнення, зменшення тощо).

2. Вибір найбільш ефективної стратегії:

Вибір залежить від:

- вартості впровадження;
- очікуваного ефекту;
- вимог законодавства;
- прийнятного рівня ризику для організації.

3. Розробка та реалізація плану дій:

Створення детального плану зі строками, відповідальними особами, необхідними ресурсами.

4. Верифікація ефективності заходів:

Після реалізації заходів потрібно оцінити, наскільки вони знизили ризик (зокрема — повторний аналіз залишкового ризику).

5. Оновлення реєстру ризиків:

Вносяться зміни щодо статусу ризиків, прийнятих заходів, відповідальних осіб тощо.

Важливо:

- ISO 31010:2013 також включає **методи оцінки ризику**, які допомагають на цьому етапі, наприклад: аналіз сценаріїв, дерева рішень, аналіз впливу (impact assessment), SWOT-аналіз тощо.
 - Ризик не завжди підлягає усуненню — часто йдеться про **зменшення до прийняттого рівня**, визначеного політикою організації.
-

2. Перелічіть основні стратегії обробки ризиків (5 балів)

Згідно з ISO 31000 / ISO 31010, існує **п'ять основних стратегій (варіантів) обробки ризику**:

1.  **Уникнення ризику (Risk Avoidance):**
Відмова від дій, що створюють ризик. Наприклад: не впроваджувати нестабільну технологію.
 2.  **Зменшення ризику (Risk Reduction):**
Застосування заходів, що зменшують ймовірність або наслідки ризику (наприклад: встановлення антивірусу, фаєрвола, навчання персоналу).
 3.  **Передача ризику (Risk Transfer):**
Перенесення відповідальності на третю сторону (страхування, аутсорсинг, контрактні зобов'язання).
 4.  **Прийняття ризику (Risk Acceptance):**
Усвідомлене рішення не вживати заходів, якщо ризик не перевищує прийнятний рівень.
 5.  **Поділ або розподіл ризику (Risk Sharing):**
Варіант передачі частини ризику між кількома сторонами (наприклад, спільні інвестиції або хмарні сервіси з поділом відповідальності).
-

Якщо бажаєш — можу надати приклади для кожної стратегії або таблицю порівняння стратегій у вигляді конспекту.

Ось розгорнуті та чітко структуровані відповіді на обидва запитання:

1. Що означає стратегія прийняття ризику. Наведіть приклад (10 балів)

✔ Стратегія прийняття ризику (Risk Acceptance)

Прийняття ризику — це свідоме рішення **не вживати додаткових заходів** щодо зниження ризику, якщо:

- ризик оцінюється як **допустимий** або низький;
- витрати на заходи захисту **перевищують очікувану шкоду**;
- **неможливо або недоцільно** з технічної чи економічної точки зору усунути ризик.

Ця стратегія **не означає бездіяльність**. Ризик все одно **контролюється та моніториться**, але **без активного втручання** на етапі обробки.

● Приклад:

Організація використовує публічну Wi-Fi-мережу для гостьового доступу, яка **відокремлена від внутрішньої корпоративної мережі**.

Ризик: можливість перехоплення трафіку гостьової мережі.

- Оскільки **гостьова мережа не містить конфіденційної інформації**, і з неї немає доступу до внутрішніх ресурсів,
 - а витрати на впровадження шифрування або авторизації оцінено як надлишкові —
👉 **організація приймає ризик**, визнаючи його **незначним і контрольованим**.
-

■ Додатково:

- Стратегія прийняття **часто використовується** для **залишкових ризиків**, які залишаються після обробки основних загроз.
 - Обов'язково **документується** у плані управління ризиками або реєстрі ризиків.
-

2. Що таке ідентифікування ризику відповідно до ДСТУ ІЕС/ISO 31010:2013 (5 балів)

🔍 Ідентифікування ризику (Risk Identification)

Це перший практичний етап процесу управління ризиками згідно з ДСТУ ІЕС/ISO 31010:2013, який полягає у **виявленні потенційних ризиків**.

Мета:

- Визначити, що може піти не так,
 - які **активи**, **загрози** і **вразливості** існують,
 - які **наслідки** це може мати для організації.
-

Основні завдання ідентифікування ризиків:

1. **Виявлення активів, що потребують захисту**
(інформація, ІТ-системи, люди, інфраструктура)
 2. **Виявлення потенційних загроз і вразливостей**
(віруси, людський фактор, відмова обладнання, помилки конфігурації)
 3. **Формування переліку ризиків**, які можуть виникнути в результаті реалізації загроз через вразливості.
-

Методи, які описані в ISO 31010 для ідентифікації ризиків:

- Експертні інтерв'ю
 - Аналіз контрольних списків (checklists)
 - SWOT-аналіз
 - Аналіз сценаріїв
 - Метод мозкового штурму
 - Аналіз подій, що вже відбулися (incident history)
-

Приклад:

Під час ідентифікації ризиків для серверної виявлено:

- Актив: сервер бази даних
- Загроза: перегрів обладнання
- Вразливість: відсутність резервного живлення кондиціонера
- Потенційний ризик: зупинка сервера та втрата доступу до даних

Цей ризик буде надалі оцінено та оброблено.

Ось повна відповідь на обидва запитання з поясненнями та прикладами:

1. Наведіть приклади оцінювання ризиків за ДСТУ ІЕС/ISO 31010:2013 (10 балів)

Оцінювання ризику (Risk Assessment) згідно з ДСТУ ІЕС/ISO 31010:2013
— це поєднання трьох етапів:

- ідентифікація ризику,
- аналіз ризику,
- оцінювання рівня ризику (чи прийнятний ризик і чи потребує обробки).

У стандарті наведено **різні методи оцінювання ризиків**, які залежать від складності, галузі та наявності даних.

Типові приклади методів оцінювання ризику:

Метод	Суть	Приклад
SWIFT (Structured What-If Technique)	Аналіз «А що, якщо...?»	"Що буде, якщо адміністратор помилково видалить критичну БД?"
Метод контрольного списку (Checklist)	Перевірка відповідності визначеним вимогам	Перелік запитань типу: "Чи активований брандмауер?"
Аналіз сценаріїв (Scenario Analysis)	Оцінювання ризиків на основі детального опису можливих інцидентів	Сценарій кібератаки через фішинг → зараження системи → витік даних
FMEA (Failure Modes and Effects Analysis)	Визначення, які елементи системи можуть вийти з ладу і які наслідки це матиме	Розгляд виходу з ладу сервера, джерел живлення, мережевого обладнання
Аналіз дерева відмов (FTA)	Побудова дерева логічних причин, які можуть призвести до небажаної події	Основна подія: "Втрата доступу до сайту" → через "DDOS", "помилку мережі", "відмову DNS"

Метод	Суть	Приклад
Матриця ризику (Risk Matrix)	Побудова таблиці ймовірність × наслідки для ранжування ризиків	Висока ймовірність × серйозні наслідки = критичний ризик
Кількісне оцінювання ризику (Quantitative Risk Assessment)	Розрахунок ризику у грошовому вираженні: Risk = Impact × Probability	Якщо вірогідність атаки 10% і збитки \$100,000 → очікувані втрати \$10,000

● Висновок:

Методи з ISO 31010 можна комбінувати. Наприклад, почати з чек-листа → деталізувати за допомогою FMEA → сформувати матрицю ризиків.

2. В чому полягає аналіз ризиків кібербезпеки (5 балів)

● Аналіз ризиків кібербезпеки — це процес оцінювання і розуміння рівня ризику, пов'язаного з інформаційними системами, що піддаються кіберзагрозам.

Основні складові аналізу кіберризиків:

- 1. Визначення активів**
→ Що потрібно захищати? (Сервери, бази даних, паролі, персональні дані)
- 2. Виявлення загроз**
→ Що може завдати шкоди? (Хакери, віруси, внутрішні порушники, людські помилки)
- 3. Виявлення вразливостей**
→ Як можуть реалізуватися загрози? (Непатчене ПЗ, слабкі паролі, відсутність логування)
- 4. Оцінка впливу і ймовірності**
→ Які будуть наслідки інциденту і наскільки це ймовірно?
- 5. Визначення рівня ризику**
→ Наприклад:
 - Високий: витік персональних даних через злам VPN

- Середній: фішинг без доступу до критичних систем
 - Низький: несвоєчасне оновлення плагіна на внутрішньому сайті
-

 Мета аналізу:

- Приймати обґрунтовані рішення щодо впровадження засобів захисту.
 - Зосередити ресурси на найважливіших загрозах.
 - Визначити залишкові ризики.
-

Якщо потрібно — можу додати приклад аналізу кіберризиків у вигляді таблиці для лабораторної чи курсової роботи.

Звісно! Ось структурована відповідь у формі чіткого пояснення з логічним порядком:

1. Приклад обробки стратегії ризиків «ухилення» (10 балів)

Пояснення:

Стратегія ухилення від ризику означає повне уникнення дій, які можуть створити небажані ризики. Тобто, замість того щоб зменшити ризик, організація просто **не виконує діяльність, що його породжує**.

Приклад ситуації:

Компанія розглядає можливість впровадження політики "Bring Your Own Device" (BYOD), що дозволяє працівникам використовувати особисті ноутбуки для доступу до корпоративної мережі.

Оцінка ризику:

Було встановлено, що такий підхід:

- значно підвищує ризик зараження мережі шкідливим програмним забезпеченням;
- ускладнює контроль за дотриманням політик безпеки;
- може призвести до витоку конфіденційної інформації.

Прийняте рішення:

Компанія **відмовляється впроваджувати політику BYOD**. Замість цього вона надає працівникам **корпоративні пристрої**, які вже мають встановлене антивірусне програмне забезпечення, контроль доступу та шифрування даних.

Висновок:

Ризик було повністю усунуто шляхом **відмови від дії**, що могла його спричинити. Це і є реалізація стратегії «ухилення».

2. Вміст стандарту ISO/IEC 27005 та його відношення до ризиків інформаційної безпеки (5 балів)

Пояснення:

Стандарт ISO/IEC 27005:2018 — це міжнародний стандарт, що описує **процес управління ризиками інформаційної безпеки**. Він підтримує впровадження системи управління інформаційною безпекою згідно з ISO/IEC 27001.

Що містить стандарт:

1. **Контекст організації** – визначення потреб, активів і зовнішнього/внутрішнього середовища.
2. **Ідентифікація ризиків** – виявлення загроз, вразливостей, активів і потенційних інцидентів.
3. **Аналіз і оцінювання ризиків** – оцінка ймовірності та впливу ризиків для встановлення їх критичності.
4. **Обробка ризиків** – вибір і реалізація стратегій: уникнення, зниження, передача або прийняття.
5. **Моніторинг та перегляд** – постійне відстеження змін у ризиках та ефективності заходів.
6. **Комунікація та консультації** – взаємодія між учасниками процесу управління ризиками.

Відношення до інформаційної безпеки:

Цей стандарт надає організаціям **чіткий підхід до виявлення та управління ризиками**, пов'язаними з конфіденційністю, цілісністю та доступністю інформації. Він допомагає ухвалювати обґрунтовані рішення щодо безпеки та розставляти пріоритети в захисних заходах.

Якщо потрібно — можу окремо пояснити кожен етап ISO/IEC 27005 або допомогти скласти приклад процесу управління ризиками в інформаційній системі.

Ось структурована відповідь на обидва запитання:

1. Перерахуйте всі відомі вам стандарти серії ISO/IEC 27000, які містять інструментарій для боротьби з ризиками (10 балів)

Серія стандартів **ISO/IEC 27000** присвячена управлінню інформаційною безпекою (ІБ). Багато з них безпосередньо стосуються **управління ризиками**, тобто описують методи, принципи або практичні інструменти для їх ідентифікації, аналізу та обробки.

Ось ключові стандарти:

1. **ISO/IEC 27000** — Опис термінів і визначень, що використовуються в серії стандартів 27000. Формує основу для розуміння ризиків і пов'язаних процесів.
2. **ISO/IEC 27001** — Основний стандарт для впровадження **Системи управління інформаційною безпекою (СУІБ)**. Містить вимоги до процесу оцінювання та обробки ризиків ІБ.
3. **ISO/IEC 27002** — Надає **практичні рекомендації щодо контролів** (засобів захисту), які можуть бути застосовані для зниження ризиків. Є доповненням до 27001.
4. **ISO/IEC 27005** — Повністю присвячений **управлінню ризиками інформаційної безпеки**. Описує процеси: ідентифікацію, оцінку, аналіз, обробку та моніторинг ризиків. Це головний інструмент для боротьби з ризиками в серії 27000.
5. **ISO/IEC 27017** — Містить **рекомендації для контролів безпеки у хмарних обчисленнях**, з урахуванням ризиків, специфічних для хмари.
6. **ISO/IEC 27018** — Розширює заходи захисту **персональних даних у хмарних сервісах**. Фокусується на **ризиках для конфіденційності**.
7. **ISO/IEC 27019** — Застосування стандартів ІБ до **енергетичної галузі**, з урахуванням галузевих ризиків.

8. **ISO/IEC 27701** (часто розглядається як розширення 27001/27002) — Система управління інформацією про персональні дані. Включає оцінювання ризиків для конфіденційності.
-

2. Що собою являє управління ризиками інформаційної безпеки? (5 балів)

Управління ризиками інформаційної безпеки — це систематичний процес виявлення, оцінювання, аналізу, обробки та моніторингу ризиків, що можуть впливати на конфіденційність, цілісність і доступність інформації.

Цей процес дозволяє:

- виявити **загрози та вразливості**;
- оцінити ймовірність і потенційні **наслідки інцидентів**;
- обрати **відповідні заходи захисту** (наприклад, шифрування, резервне копіювання, контроль доступу);
- **знижити або усунути ризики** до прийнятного рівня;
- приймати **обґрунтовані рішення** щодо ІБ на основі ризик-орієнтованого підходу.

Таким чином, управління ризиками — це **основа всієї системи ІБ**, що дозволяє ефективно використовувати ресурси для захисту організації.

Ось структурована і зрозуміла відповідь на обидва запитання:

1. Приклади стандартних методів, які застосовуються в стратегії обробки ризиків «мінімізація» (10 балів)

Стратегія мінімізації (зниження) ризику передбачає впровадження заходів, які зменшують:

- **ймовірність виникнення загрози** або
- **серйозність наслідків**, якщо загроза реалізується.

Стандартні методи зниження ризиків:

1. Технічні заходи:

- **Шифрування даних** — захищає інформацію під час передавання або зберігання.
- **Брандмауери (фаєрволи)** — обмежують небажаний мережевий трафік.
- **Системи виявлення вторгнень (IDS/IPS)** — виявляють та/або блокують підозрілу активність.
- **Резервне копіювання (backup)** — дозволяє відновити дані після збоїв або атак.
- **Оновлення ПЗ (патч-менеджмент)** — усуває відомі вразливості.

2. Адміністративні заходи:

- **Розподіл обов'язків** — мінімізує ризик зловживань (наприклад, окремі особи відповідають за аудит і за доступ).
- **Політики безпеки** — обмежують дії користувачів (наприклад, заборона використання USB).
- **Регулярне навчання персоналу** — зменшує ризик соціальної інженерії.
- **Доступ за принципом найменших привілеїв (PoLP)** — користувачі мають лише необхідні для роботи права.

3. Фізичні заходи:

- **Контроль доступу до серверних кімнат.**
- **Відеоспостереження** для контролю дій персоналу.
- **Сейфи, замки, біометрія** для захисту носіїв даних.

Приклад:

Щоб мінімізувати ризик несанкціонованого доступу до даних, організація вводить:

- автентифікацію за двома факторами (2FA);
- шифрування бази даних;
- моніторинг логів входу;
- обмеження доступу лише до потрібної інформації.

2. Поясніть процес ідентифікування ризиків відповідно до вимог нормативних документів (5 балів)

Ідентифікування ризиків — це перший і критично важливий етап управління ризиками, на якому виявляються **потенційні загрози, вразливості, активи та події**, які можуть мати негативний вплив на організацію.

Згідно з ISO/IEC 27005 і ДСТУ IEC/ISO 31010:2013, процес включає:

1. Визначення активів:

- Що саме потрібно захищати (інформація, ІТ-системи, бази даних, персональні дані тощо).

2. Визначення загроз:

- Що може завдати шкоди активам?
Наприклад: віруси, хакери, внутрішні зловмисники, пожежа, збій електроживлення.

3. Визначення вразливостей:

- Які слабкі місця існують у системі?
Наприклад: застаріле ПЗ, слабкі паролі, відсутність журналювання, неналаштований фаєрвол.

4. Виявлення можливих інцидентів:

- Які події можуть трапитися внаслідок взаємодії загроз і вразливостей?

5. Документування:

- Усі ризики описуються, класифікуються та реєструються для подальшого аналізу.

Інструменти для ідентифікації ризиків (згідно з ISO 31010):

- контрольні списки (checklists),
 - SWOT-аналіз,
 - аналіз сценаріїв,
 - інтерв'ю з експертами,
 - аналіз історичних інцидентів.
-

Ось чітка та структурована відповідь на обидва запитання відповідно до ДСТУ ІЕС/ISO 31010:2013:

1. У чому полягає етап оброблення ризиків відповідно до ДСТУ ІЕС/ISO 31010:2013 (10 балів)

Оброблення ризиків — це четвертий етап у процесі управління ризиками, після їх ідентифікації, аналізу та оцінювання. Його мета — **зменшити ризики до прийнятного рівня** шляхом вибору та впровадження відповідних заходів.

Основні дії етапу оброблення ризиків:

1. Вибір стратегії обробки ризику:

Залежно від оцінки ризику та цілей безпеки обирається одна з таких стратегій:

- **Ухилення (Avoidance):** повне усунення джерела ризику.
- **Мінімізація (Mitigation):** зменшення ймовірності або наслідків.
- **Передача (Transfer):** передача ризику третій стороні (наприклад, страхування, аутсорсинг).
- **Прийняття (Acceptance):** свідоме погодження на ризик без додаткових заходів.

2. Оцінка ефективності заходів:

- Чи зменшує захід рівень ризику до прийнятного?
- Чи не створює він нових ризиків?

3. Вибір конкретних заходів:

Приклади:

- Технічні (фаєрволи, шифрування, IDS).
- Адміністративні (політики, навчання).
- Фізичні (контроль доступу, відеонагляд).

4. Розробка плану впровадження:

- Кроки реалізації.
- Відповідальні особи.
- Строки.

5. Моніторинг і перегляд:

- Перевірка, чи справді заходи працюють.
 - Актуалізація обробки ризиків при зміні середовища.
-

2. Які процеси охоплює загальне оцінювання ризиків відповідно до ДСТУ ІЕС/ISO 31010:2013 (5 балів)

Загальне оцінювання ризиків (Risk Assessment) за стандартом охоплює **три ключові процеси**, які йдуть один за одним:

1. Ідентифікація ризиків (Risk Identification):

- Виявлення того, що може піти не так.
- Визначення загроз, вразливостей, активів, інцидентів.
- Результат — перелік потенційних ризиків.

2. Аналіз ризиків (Risk Analysis):

- Оцінка ймовірності та наслідків кожного ризику.
- Визначення рівня ризику (кількісний або якісний).
- Може враховувати чинники, які впливають на ризик (контрольні заходи, слабкі місця).

3. Оцінювання ризиків (Risk Evaluation):

- Порівняння отриманого рівня ризику з критеріями прийнятності.
 - Визначення, які ризики потребують оброблення, а які — можна прийняти.
-

Звичайно! Ось структуровані відповіді на ваші запитання:

1. Приклади стандартних методів, які застосовуються в стратегії обробки ризиків «ухилення» (10 балів)

Стратегія ухилення від ризику (Avoidance) передбачає повне усунення джерела ризику або припинення дій, які можуть його спричинити. Мета — уникнути появи ризикової ситуації взагалі.

Приклади методів ухилення від ризику:

- **Зміна процесів або діяльності:**
Відмова від впровадження небезпечної технології або програмного продукту, який має відомі уразливості.
- **Відмова від діяльності або проекту:**
Наприклад, не запускати певний бізнес-проект, якщо він пов'язаний з високими ризиками кібербезпеки, які неможливо контролювати.
- **Зміна умов або вимог:**
Відмова від обробки конфіденційних даних на зовнішніх серверах, якщо існують сумніви щодо їх безпеки.
- **Використання безпечних альтернатив:**
Заміна небезпечного обладнання або технології на більш безпечні аналоги.
- **Відмова від використання певних сервісів чи функцій:**
Наприклад, блокування використання зовнішніх USB-накопичувачів, щоб уникнути ризику зараження шкідливим ПЗ.
- **Перенесення бізнес-процесів:**
Перенесення діяльності у регіон з кращою законодавчою базою для захисту даних.

2. Приклад формули для обрахунку ризиків (5 балів)

Найпоширеніша формула для оцінки ризику:

Ризик=Ймовірність×Наслідки $\boxed{\text{Ризик} = \text{Ймовірність} \times \text{Наслідки}}$

- **Ймовірність (Р)** — ймовірність настання небажаної події (загрози).
- **Наслідки (І)** — ступінь шкоди або збитків, які виникнуть у разі реалізації ризику.

Розширені варіанти формули:

1. З урахуванням рівня контролю:

Ризик=Ймовірність×НаслідкиЕфективність контролю $\text{Ризик} = \frac{\text{Ймовірність} \times \text{Наслідки}}{\text{Ефективність \, контролю}}$

2. Формула із врахуванням уразливості:

Ризик=Загроза×Уразливість×Наслідки $\text{Ризик} = \text{Загроза} \times \text{Уразливість} \times \text{Наслідки}$

1. Чи вимагає обов'язкового документування процес оцінювання ризиків? Якщо так, то наведіть приклади такої документації (10 балів)

Так, процес оцінювання ризиків обов'язково документується відповідно до вимог міжнародних стандартів, зокрема ISO/IEC 27005 та ДСТУ ІЕС/ISO 31010:2013. Це необхідно для прозорості, обґрунтованості рішень, можливості перевірки та повторного аналізу.

Під час цього процесу створюється кілька ключових документів. Наприклад, основним є реєстр ризиків — таблиця або звіт, де фіксуються всі виявлені ризики, їх джерела, ймовірність настання, потенційні наслідки, рівень ризику, наявні заходи контролю і рекомендації щодо реагування. Ще одним прикладом документа є звіт з аналізу ризиків, який містить опис методів оцінювання, вихідні дані, критерії прийнятності ризику, а також висновки та пропозиції щодо його зменшення або прийняття. Також часто оформлюють карти ризиків (risk maps), в яких ризики візуалізуються на координатній площині ймовірність/наслідки. У великих організаціях до документації можуть також входити протоколи засідань груп з оцінки ризиків, накази про затвердження рішень і плани обробки ризиків.

Документування гарантує, що процес був виконаний системно і може бути використаний як доказ відповідності при зовнішніх або внутрішніх аудитах.

2. Навіщо проводиться процес повторного оцінювання ризиків? (5 балів)

Повторне оцінювання ризиків проводиться для того, щоб врахувати зміни, які могли відбутися з часом у середовищі організації, технологіях, законодавстві, загрозах або вразливостях. Ризики не є статичними — вони змінюються разом із розвитком інформаційної системи, появою нових загроз або змін у бізнес-процесах.

Також повторна оцінка дозволяє перевірити ефективність вже впроваджених заходів безпеки: можливо, деякі ризики було знижено, деякі — виникли заново. Регулярний перегляд ризиків забезпечує актуальність реєстру ризиків, підвищує стійкість системи до загроз і дозволяє вчасно приймати рішення щодо впровадження нових заходів захисту.

1. Назвіть та обґрунтуйте найбільш ризиковану властивість інформації типу «Публічна» (10 балів)

Найбільш ризикованою властивістю публічної інформації є **доступність**, оскільки вона передбачає вільний або майже вільний доступ до даних широкого кола осіб без автентифікації. Саме ця відкритість, попри її переваги для прозорості й інформування, створює потенційно серйозні загрози для інформаційної безпеки.

Найбільший ризик полягає в тому, що **публічна інформація може бути використана як інструмент для підготовки атак**. Наприклад, з відкритих джерел можна дізнатися структуру організації, контактні дані працівників, використовувані технології — усе це є цінною інформацією для зломисників при здійсненні соціальної інженерії, фішингових атак чи технічного сканування систем. Крім того, якщо відбувається ненавмисне публікування чутливої інформації (наприклад, конфігурацій, службових документів, списків облікових записів тощо), це може призвести до порушення конфіденційності або навіть компрометації системи.

Таким чином, хоча публічна інформація за визначенням не має обмежень у доступі, саме її **широка доступність робить її найвразливішою**, якщо не контролювати вміст і джерело розповсюдження.

2. Чи завжди вимагається мінімізувати ризики, що виникають в інформаційній системі? Обґрунтуйте відповідь (5 балів)

Ні, мінімізувати ризики в інформаційній системі потрібно **не завжди**. Міжнародні стандарти управління ризиками (зокрема, ISO/IEC 27005 та ISO 31000) наголошують на принципі **обґрунтованого управління**, а не на повному усуненні ризиків. У практиці існує декілька стратегій обробки ризиків, серед яких — не тільки мінімізація (зниження), а й прийняття (акцепт), передача (наприклад, шляхом страхування) або ухилення.

Ризик доцільно мінімізувати лише тоді, коли:

- його рівень перевищує встановлені порогові значення прийнятності;
- витрати на зниження не перевищують потенційної шкоди;
- існують технічні або організаційні можливості для його зменшення.

Проте є ситуації, коли мінімізація є **невиправданою економічно або технічно**. Наприклад, якщо вірогідність події дуже низька, а наслідки — незначні, організація може вирішити прийняти ризик без активного втручання. Такий підхід дозволяє ефективно використовувати ресурси та зосередити увагу на дійсно критичних ризиках.

Отже, **мінімізація — лише один з варіантів реагування**, який застосовується вибірково, залежно від контексту та характеру загроз.

1. Принцип вибору методів оцінювання ризиків за ДСТУ ІЕС/ISO 31010:2013 (10 балів)

Вибір методів оцінювання ризиків за ДСТУ ІЕС/ISO 31010:2013 ґрунтується на адаптації до мети, контексту та ресурсів організації. Ключовим є

забезпечення відповідності методу конкретним потребам оцінювання. Наприклад, якщо потрібно швидко виявити загрози, використовуються прості техніки, такі як структурований аналіз "Що-якщо". Для глибокого аналізу складних систем, як у кібербезпеці, застосовують кількісні методи, наприклад аналіз Монте-Карло або дерево подій.

Важливим фактором є наявність даних: за їх браку ефективні якісні методи, як-от матриця ризиків, а за наявності статистики — кількісні, такі як аналіз дерева відмов. Ресурси організації також відіграють роль: обмежений бюджет чи персонал схиляє до простих методів, тоді як розвинена система управління ризиками дозволяє застосовувати складніші, наприклад FMEA.

Стадія процесу впливає на вибір: на етапі планування акцент на ідентифікацію ризиків, а під час експлуатації — на моніторинг. Стандарт рекомендує комбінувати методи для точнішого результату, балансуючи між витратами, точністю та цілями організації.

2. Приклади методів для стратегії обробки ризиків «прийняття» (5 балів)

Стратегія прийняття ризику застосовується, коли ризик вважається допустимим і не вимагає активного втручання. Основний метод — це фіксація рішення в офіційній документації, наприклад, через оформлення наказу чи протоколу, де зазначається, що ризик свідомо приймається через його низьку ймовірність чи незначний вплив.

Інший метод — внесення ризику до реєстру ризиків із зазначенням причин прийняття та графіку періодичного перегляду, щоб своєчасно реагувати на зміни умов. Наприклад, організація може прийняти ризик втрати некритичних даних через низьку ймовірність витоку, задокументувавши це в реєстрі та визначивши дату повторної оцінки.

Такий підхід забезпечує прозорість і контроль, не витрачаючи ресурси на надмірний захист.

1. Процес класифікації ризиків та приклади класифікації (10 балів)

****Процес класифікації ризиків**** полягає в систематизації та групуванні ризиків за певними ознаками для полегшення їх ідентифікації, аналізу та управління. Це дозволяє організаціям чітко визначити пріоритети, розподілити ресурси та розробити ефективні стратегії управління. Процес включає кілька етапів:

- ****Ідентифікація ризиків****: Виявлення всіх потенційних ризиків, що можуть вплинути на інформаційні активи. Наприклад, це можуть бути кібератаки, збої обладнання чи людські помилки.
- ****Визначення критеріїв класифікації****: Ризики групуються за джерелами, типами, впливом чи іншими характеристиками. Критерії залежать від цілей організації та контексту.
- ****Групування ризиків****: Поділ ризиків на категорії для спрощення аналізу та обробки. Це може бути виконано за допомогою таблиць, матриць або спеціалізованого програмного забезпечення.
- ****Документування****: Фіксація класифікованих ризиків у реєстрі ризиків із зазначенням категорій, ймовірності та впливу.

****Приклади класифікації ризиків** у контексті інформаційної безпеки:**

- ****За джерелом ризику****:
 - Зовнішні ризики: хакерські атаки, фішинг, DDoS-атаки.
 - Внутрішні ризики: помилки співробітників, ненавмисне розкриття даних.
- ****За впливом на принципи CIA****:
 - Ризики конфіденційності: витік клієнтських даних через слабе шифрування.
 - Ризики цілісності: зміна даних у базі через вірус.
 - Ризики доступності: зупинка сервісів через збій сервера.
- ****За типом загрози****:
 - Технічні: збої програмного забезпечення, вразливості в системах.
 - Організаційні: недостатнє навчання персоналу, слабкі політики безпеки.
 - Фізичні: крадіжка обладнання, пошкодження серверів через стихійні лиха.

Класифікація допомагає структурувати ризики, наприклад, у матриці ризиків, де кожен ризик оцінюється за ймовірністю та впливом, що сприяє ефективному управлінню.

2. Нормативний документ про політику управління ризиками інформаційної безпеки (5 балів)

****Нормативний документ****: Основним міжнародним стандартом, який містить відомості про політику управління ризиками інформаційної безпеки, є ****ISO/IEC 27005:2018**** (Інформаційна безпека, кібербезпека та захист конфіденційності — Керівництво з управління ризиками інформаційної безпеки).

****Обґрунтування****:

- ISO/IEC 27005:2018 спеціально розроблений для управління ризиками інформаційної безпеки та є частиною сімейства стандартів ISO/IEC 27000.

Він детально описує процеси ідентифікації, оцінки, обробки та моніторингу ризиків, а також принципи розробки політики управління ризиками.

- Стандарт визначає, як інтегрувати управління ризиками в систему управління інформаційною безпекою (СУІБ), відповідно до ISO/IEC 27001.

Він включає рекомендації щодо створення політики, яка охоплює критерії оцінки ризиків, методи їх обробки та ролі відповідальних осіб.

- На відміну від загального стандарту ISO 31000 (який стосується управління ризиками будь-якого типу), ISO/IEC 27005 фокусується саме на інформаційній безпеці, що робить його ключовим для цього контексту.

Цей документ є основою для розробки політики управління ризиками інформаційної безпеки в організаціях, які прагнуть відповідати міжнародним стандартам.